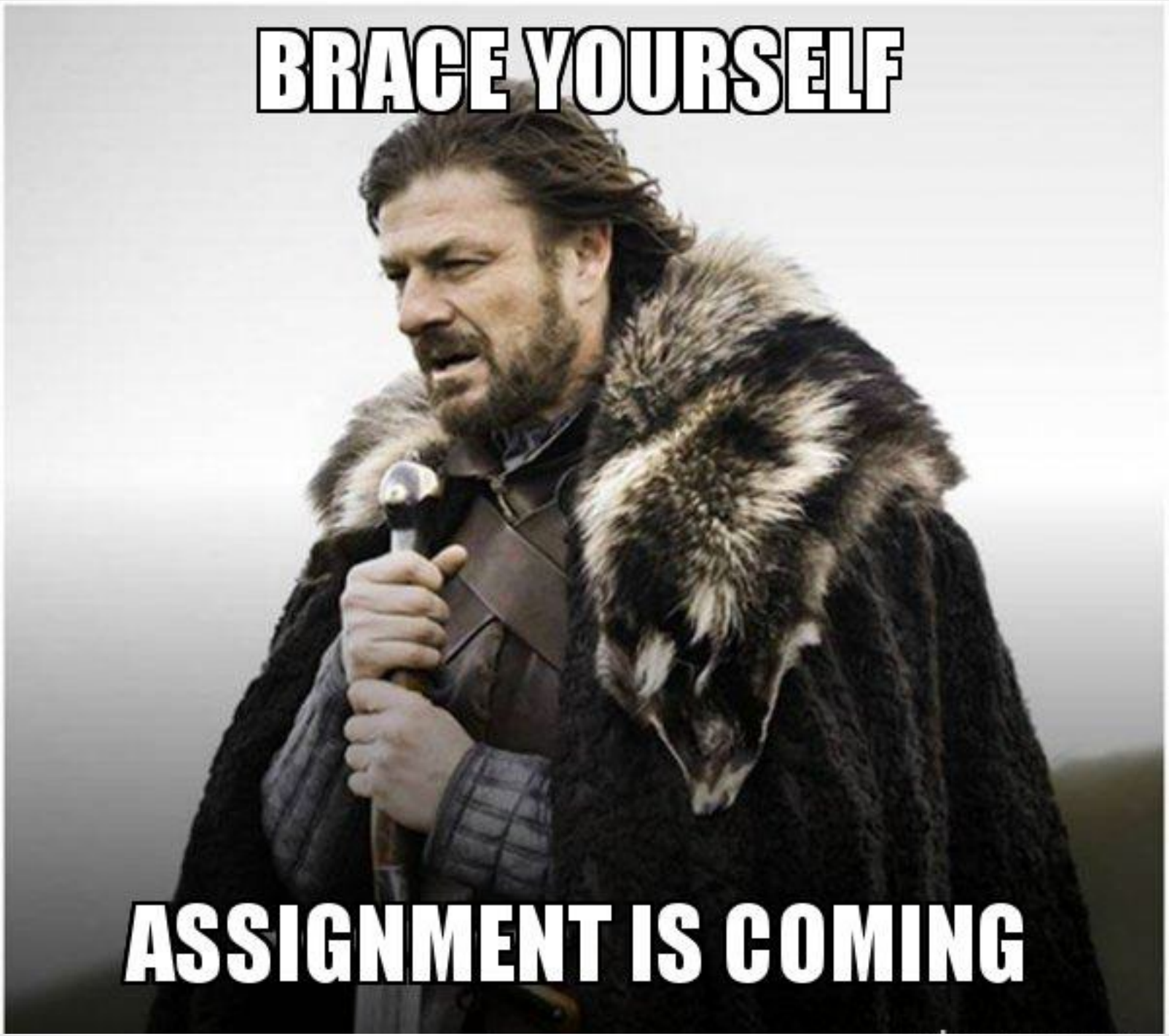
OCTAVE Risk Evaluation Framework

By **Kavinga Yapa Abeywardena**

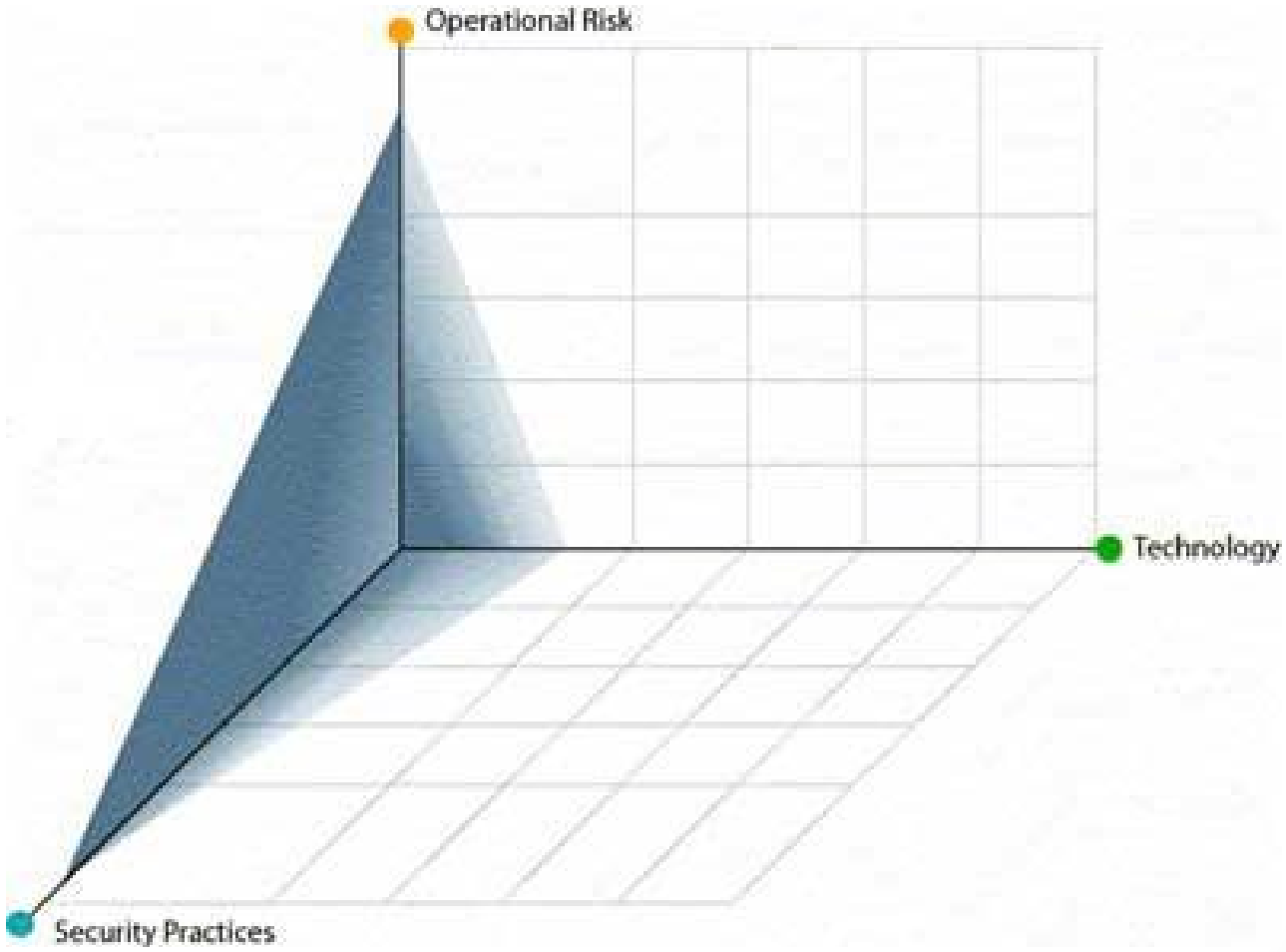
Sri Lanka Institute of Information Technology (SLIIT)


BRACE YOURSELF
ASSIGNMENT IS COMING

Operationally **C**ritical **T**hreat **A**sset & **V**ulnerability **E**valuation

- OCTAVE is a methodology for identifying and evaluating information security risks to an asset
- Set of tools, techniques and methods for risk-based information security strategic assessment and planning.
- Developed by Christopher Alberts; a scientist at Carnegie Mellon University (CMU)

OCTAVE - Big Picture



Not Technology Focused!

Image: http://www.cert.org/octave/

OCTAVE – Big Picture

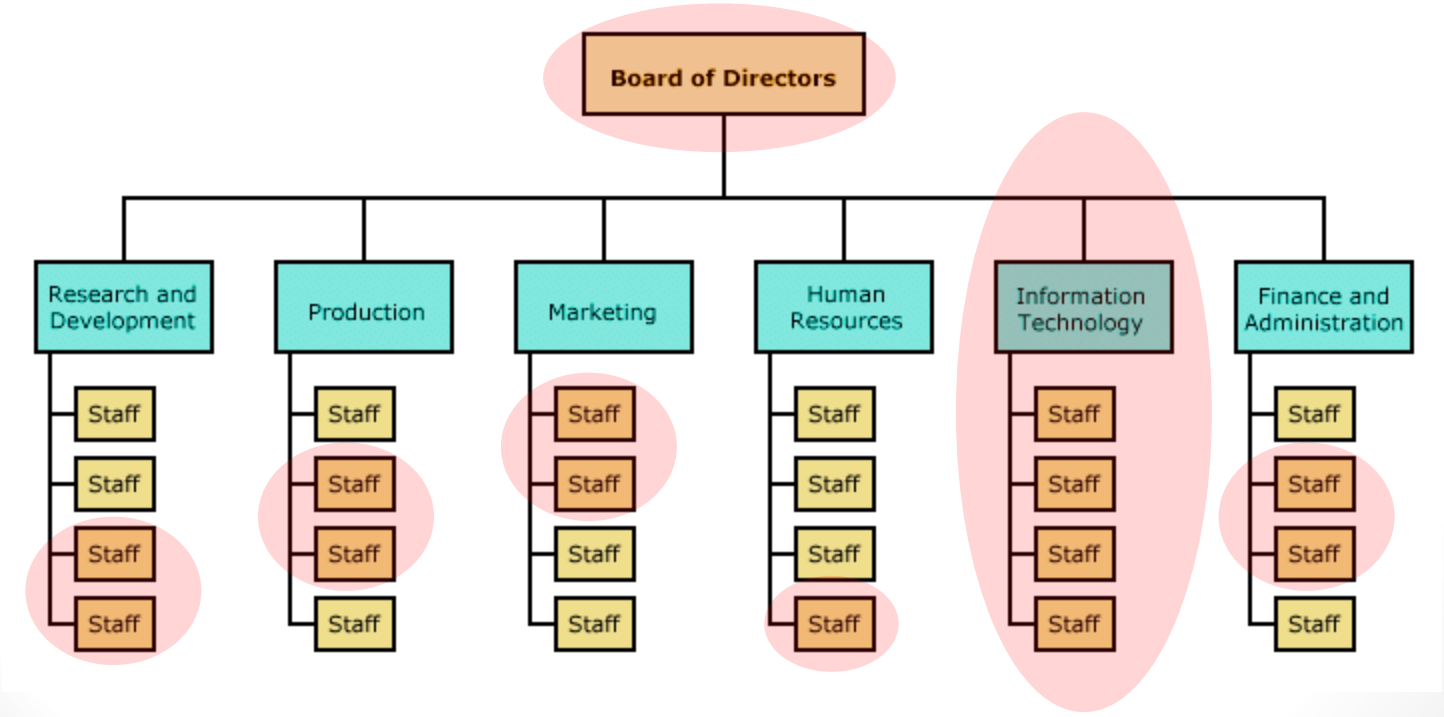
- **Philosophy/Vision**
  - Focuses on strategy
  - Take into account the organization's needs
- **Risk Assessment:**
  - Top-down approach
  - Threat-per-asset based
  - Qualitative approach
- **Implementation:**
  - Process-driven
  - Flexible: Can be customized
  - Self-directed: led by organization's employee

OCTAVE – What's Different ?

OCTAVE	Other Frameworks
Strategic Focus	Tactical Focus
Focus on Security Practices	Focus on Technology
Organization-wide evaluation	System based evaluation
Self Directed	Expert led
Top - Down	Bottom - Up

OCTAVE – Team

- **Consists of:**
  - Operational (Business) units
  - IT department



OCTAVE – Functionality

- **Functionality:**
  - Identify critical assets that are important to the organization
  - Focus risk analysis on the most important organizational assets
  - Consider:
    - Relationship between critical assets
    - Threats to assets
    - Vulnerabilities that can expose assets to threats
  - Evaluate risks in an operational context
  - Create practice-based protection strategy and risk mitigation plans to reduce risk

OCTAVE Phases - Overview

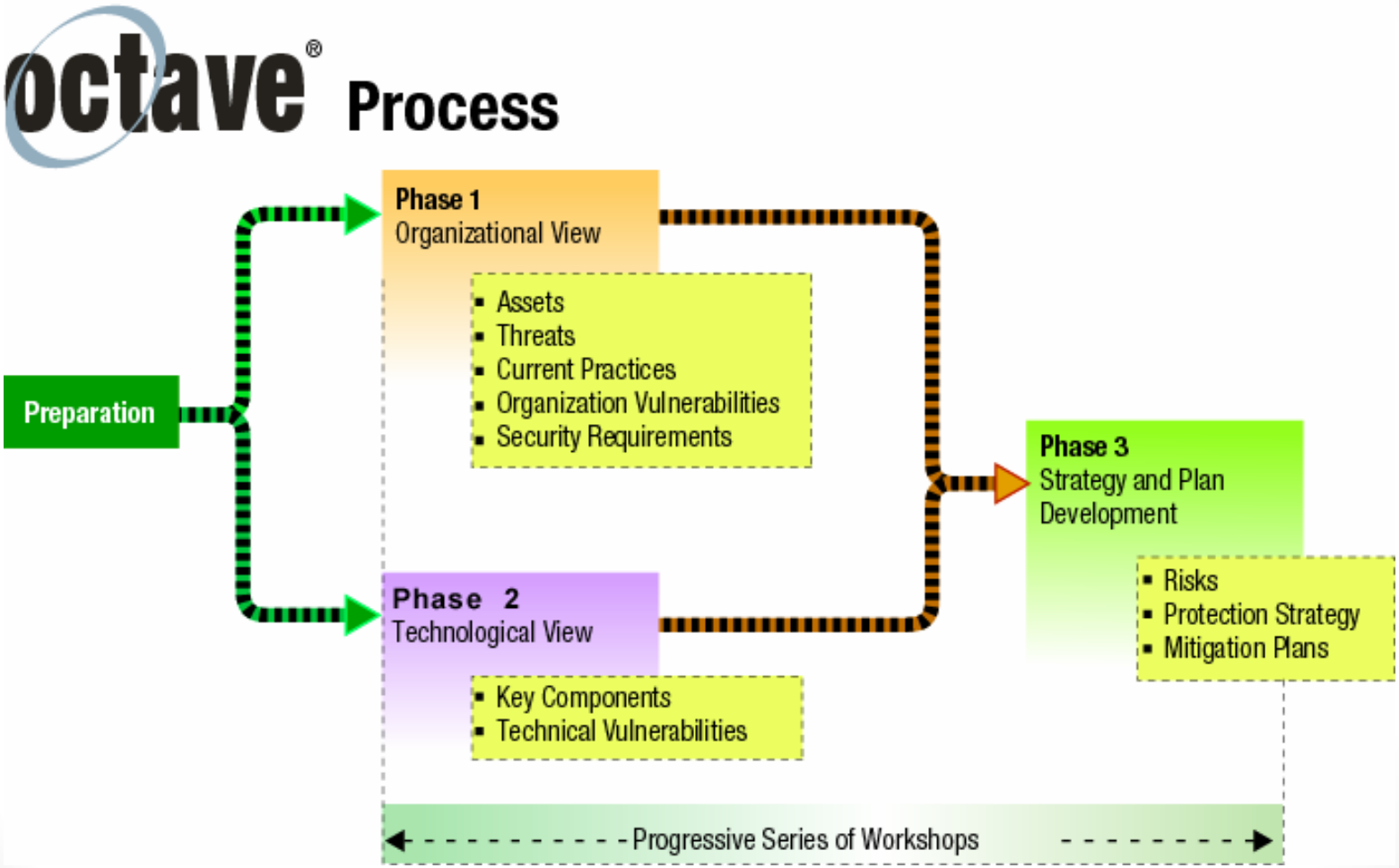


Image: http://www.cert.org/octave/

OCTAVE Phases - Overview

- Uses three-phase approach to examine organisational and technology issues
- Three Phases of OCTAVE
  - Phase 1: Build **Asset-Based Threat Profiles**
  - Phase 2: Identify Infrastructure **Vulnerabilities**
  - Phase 3: Develop **Security Strategy** and Plan
- Three phases are a composition of sub processes with each achieving a specific objective
- We will examine few important sub processes!

OCTAVE Phases & Processes

- Phase 1: Build asset-based **threat profiles**
  - Process 1: Determine **critical assets** and how they are currently protected
  - Process 2: Identify **security requirements** for each critical asset.
  - Process 3: Identify organisational **vulnerabilities** within **existing** practices
  - Process 4: Create **threat profile** for each critical asset
- Phase 2: Identify infrastructure **vulnerabilities**
  - Process 5: Identify network **access paths** and **IT components** related to critical assets
  - Process 6: **Evaluate** identified IT components
- Phase 3: Develop **security strategy** and mitigation plans
  - Process 7: Conduct **risk analysis**
  - Process 8: Develop protection **strategy and mitigation** plan

Process 4 : Threat Profile

A threat profile has the following characteristics:

- **Asset**
- **Access:** how the asset will be accessed by the actor: network or physical access (Optional)
- **Actor:** a person or natural occurrence with an undesirable outcome
- **Motive:** Actor's intentions: deliberate or accidental (Optional)
- **Outcome:** the immediate outcome of violating the security requirements of an asset
  - **Disclosure:** unauthorized access to asset
  - **Modification:** tampering with an asset
  - **Interruption** (loss/destruction): Unavailability of an asset
  - **Fabrication** (other): Creation of new objects in a system

Process 4 : Threat Profile

Example: SLIIT student records in the 'S01' server has been identified as a critical assets by Process 1.

Area of Concern	Threat Profile
People are accidentally entering the wrong data into system S01. This results in incorrect records on that system.	· **Asset** – system S01 records · **Access** – network (The data are entered into records on a system.) · **Actor** – insiders (The concern implies staff with legitimate access.) · **Motive** – accidental · **Outcome** – modification (Inconsistent data)
Someone could use the records from system S01 for personal gain.	· **Asset** – system S01 records · **Access** – network (The actor gets the records from the system.) · **Actor** – insiders and outsiders (implies staff with legitimate access as well as outsiders.) · **Motive** – deliberate · **Outcome** – disclosure (The actor is viewing information that he/she shouldn't be viewing.)

Phase 3: Risk Analysis & Security Strategy/Mitigation

- Information generated by Phases 1 and 2 are analysed to:
  - **Identify risks** to critical assets - prioritize
  - Develop **protection strategies**
  - Develop **mitigation plans**
  - Propose **next steps**
  - Senior **Management approval**

- Process 7(Risk Analysis) plays a major role. You already know how to do this!

Process 7 : Risk Analysis

- Identify & evaluate the impact of threats to critical assets
- This will form Risk Profiles: Threat profile + description of impact + impact values + Probability values
- Based on the following evaluation criteria:
  - Only focuses on **important and relevant risks**
  - **Qualitative** impact values/measures: high, medium and low
  - **Impact Areas**:
    - Reputation/customer confidence
    - Life/health of customer
    - Fines/Legal penalties
    - Financial
    - Other

OCTAVE Variants

- OCTAVE
  - large organizations ≥ 300 employees
- OCTAVE-S
  - organizations ≤ 300 employees
- OCTAVE-Allegro
  - Focuses on information assets

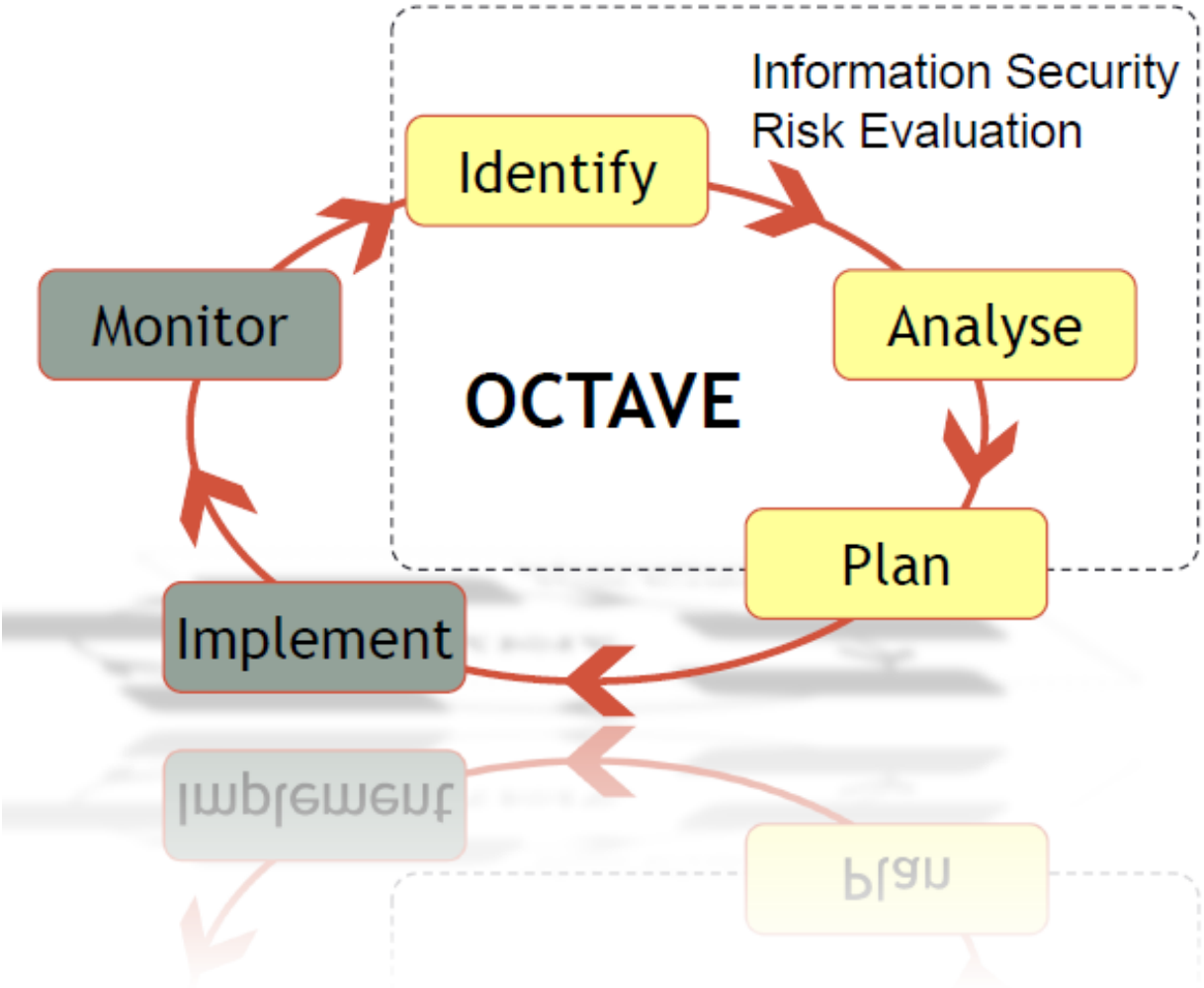
OCTAVE-S

- Developed in 2003 to cater smaller organization
- Includes a limited exploration of the computing infrastructure during Phase 2
- Requires:
  - Small organisation with a simple hierarchical structure
  - Small interdisciplinary analysis team (3-5 employees)
  - Understanding of organization's business & security processes

OCTAVE-S Deliverables

- **Organization-wide protection strategy** – strategy outlines direction with respect to information security practice
- **Risk mitigation plans** – are intended to mitigate risks to critical assets by improving selected security practices
- **Action list** – includes short-term action items needed to address specific weaknesses
- A listing of important **information-related assets** supporting the organization's business goals and objectives
- Survey results showing the extent to which the organization is following **good security practice**
- **A risk profile** for each critical asset depicting a range of risks to that asset

OCTAVE-S Scope



OCTAVE-Allegro

- Developed in 2007
- Unlike previous OCTAVE approaches, it focuses on information assets (e.g. data, hardware and software)
  - How they are used
  - Where they are stored, transported, and processed
  - How they are exposed to threats, vulnerabilities, and disruptions as a result
- Suitable to perform risk assessment without extensive organizational involvement , expertise, or input.

OCTAVE-Allegro

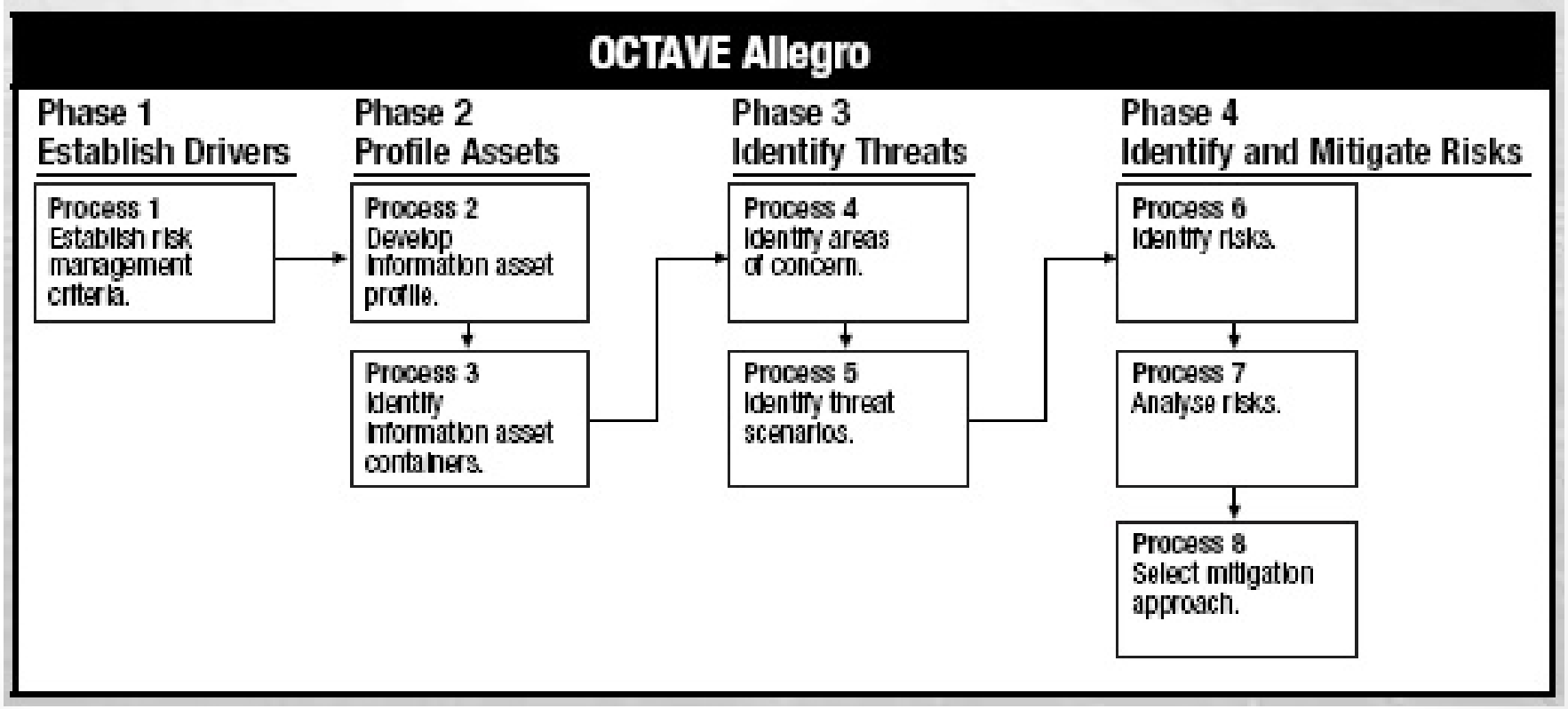


Image: http://www.isaca.org/

OCTAVE-Allegro Pros & Cons

- **Pros:**
  - Well-documented through published academic papers
  - Flexible: Organisations choose to implement portions that they find appropriate for them
  - Comprehensive
  - Focuses on important and relevant risks
  - Cheap: it is self-led

- **Cons:**
  - Needs extensive preparation
  - Complexity – exhausting processes
  - Qualitative methodology– OCTAVE does not allow organizations to mathematically model risks
  - Risk Analysis is done on a single asset– slower results which affects organizations
  - Difficult to capture futuristic threats & risks

OCTAVE – Discussion

- Flexible
- OCTAVE provides organizations an option to only choose required parts from the framework. On one hand, this might be good in terms of reducing cost, time and effort while on the other hand, some misinterpreted required parts might be missed!
- Risk analysis is performed using internal staff – not suitable for organizations interested in expertise more than lower cost
- Uses no mathematical calculations
- Uses Expected Value Matrix to determine a risk's expected value
- Values simplicity over accuracy

QUESTIONS ?




Thank
You